

## Section 1 — Fundamentals

**What is cybersecurity?** - A practice insuring confidentiality, integrity and availability of information by protecting networks, data and people from unwanted authorization and exploitation.

**What is the CIA triad?** - A security model that helps inform how organizations consider risks when setting up systems and security policies.

**What's the difference between authentication and authorization?** - Authentication is a process of confirming your identity.

Authorization is a process of giving special permissions or special access rights to a person, system or device.

**What is a vulnerability?** - A vulnerability is a flaw in a web application, that allows attackers to exploit it.

**What is an exploit?** - A code, tool or method that takes advantage of a security weakness or flaw in a computer, system, software, that can be used to steal data or break system rules.

**What is the difference between a threat, vulnerability, and risk?**

Threat is a event or action that can could harm an asset.

Vulnerability - a weakness that attackers can use to exploit it.

Risk - reflects likelihood that a threat will successfully damage an asset.

**What does the principle of least privilege mean?** - Least privileged means giving the minimum access or permissions to users, systems or a program to do their job.

**What is defense in depth?** - A cybersecurity strategy, that uses multiple overlapping security layers to protect data and systems.

## Section 2 — Web Security

**9. What is HTTP?** - Hypertext Transfer Protocol is a protocol that transfers web pages. (port 80)

**10. What is HTTPS?** - Hypertext Transfer Protocol Secure is a secure version of HTTP. It uses the TLS encryption to protect data between a web browser and the website keeping private data safe.

**11. What does TLS do?** - Security protocol, that encrypts the data sent over the internet to keep user information safe.

**12. What's a cookie?** - Data sent over to the server, to remember the users information

**13. What's a session?** - A period of time or meeting used for a specific user activity.

**14. What is SQL injection?** - Vulnerability that allows an attacker to interfere with the queries to get access to the applications database.

- 15. What is XSS?** - Cross Site Scripting is a web vulnerability that allows attackers to compromise interactions users have with a vulnerable application. Most of these vulnerabilities can be confirmed by injecting a payload, that causes the web application to execute some arbitrary JavaScript.
- 16. What is CSRF?** A vulnerability that utilizes some XSS vulnerabilities to perform certain queries and API calls on a web application that the victim is authenticated too. This means that the attacker would be allowed to perform actions as the authenticated user.
- 17. What's the difference between authentication and session management?** -Authentication confirms who the user is while the session management keeps that user logged in and tracked across subsequent requests..
- 18. What is an IDOR/access-control vulnerability?** - IDOR or Insecure Direct Object Reference is a flaw where the web app or an AIP uses an internal to fetch data.
- 19. What does Cache-Control do?** - an HTTP header that is used to specify, who, where and how long the web servers can reuse and store responses.
- 20. What kinds of things would you look for when assessing a web application?** - When accessing a web application I would look if the connection is secure, a correct trusted domain name, clear login security area.

### Section 3 — Burp Suite

- 21. What is Burp Suite?** - Burp Suite is a software that is for penetration testing web applications.
- 22. What is a proxy?** - A intermediary that sits between the client and the server, allowing the network traffic to be intercepted, modified and inspected between them.
- 23. What can you learn from an HTTP request?** - From the request we can see multiple headers that tell us about the request including the cookie session, host, HTTP method, Content-Type, ect.
- 24. What can you learn from an HTTP response?** - From the HTTP response, we can learn if the request was successful via response codes, the response body containing the HTML code, headers and header values.
- 25. What are headers?** - HTTP headers let the client and the server pass additional information with a message in a request or response.
- 26. What is the purpose of Repeater?** The Burp Suite Repeater lets us modify the request and send it again to see how the web application will behave.
- 27. What is the purpose of Intruder?** - The Intruder is a tool for customizing and automating attacks against web applications.
- 28. Why shouldn't you test a real website without authorization?** - That is because we could access someone else's systems, create legal problems, access sensitive data.
- 29. What would you document after finding a potential vulnerability?** - I would document what was it, or what gave it away like a clue as to what could the vulnerability be, but also document how it behaves.

## Section 4 — Malware 🦟

**30. What is malware?** - Malware is a malicious script, code or program that is built to disrupt, damage or steal from a computer, phone or network.

**31. What's the difference between a virus, worm, trojan, and ransomware?**

Ransomware demands ransom payment, typically in Bitcoin from people by encrypting and exfiltrating all files on the device.

A virus infects other files on the computer and replicates.

A worm spreads from one infected device to another.

A trojan pretends to be a legitimate or useful file/software to trick users into running it.

**32. What is static analysis?** - A static analysis is a type of analysis where you inspect the sample without running it.

**33. What is dynamic analysis?** - Dynamic Analysis is a type of malware analysis, where we examine the malware by running it in a isolated sandbox environment.

**34. What are indicators of compromise?** - Data and footprints, that are left on a system or network after a cyber attack has already occurred.

**35. Why might malware use obfuscation?** - It can be used to bypass antivirus or security scanners, hiding the malicious payload. Since it also can restructure the code or data to appear more confusing, it can make it harder for automated tools and humans to analyze it, so it can be used as a tactic when hiding the payloads.

**36. What kinds of things might you look for in a suspicious script?** - I would look for in dynamic analysis where the malware creates child process, also in a tool such as Wireshark observe the network activity that the malware does. And also file activity, since the malware can read files to collect the information from the operating system.

## Section 5 — Networking 🌐

**37. What is an IP address?** - An IP address stands for Internet Protocol and is a unique number that is given to a device to connect to the internet.

**38. What is DNS?** - Domain Name system translates the domain names of web pages like [example.com](https://example.com) into IP addresses.

**39. What is a port?** - A number assigned to specific processes or services on a network to help computers sort and direct network traffic correctly.

**40. What is TCP?** - Transmission Control Protocol establishes a connection between sender and receiver, guarantee delivery of data in the correct order.

**41. What is UDP?** - User Datagram Protocol focus more on delivering data fast and allows for connectionless communication without recovery error.

**42. What's the difference between a private and public IP?** A public IP connects to the home's or business's network to the internet, private IP identifies individual devices on the local network.

**43. What happens when you type a URL into a browser?** - By typing an URL into the browser, the computer translates the web address, contacts the websites server and downloads the page to display on the screen.

## Section 6 — Situational questions 🧠

### **44. You discover a vulnerability on a company's website. What do you do?**

If I discover a vulnerability, as a Junior Cybersecurity employee, I would firstly skim over and see if I understand what is happening without touching DevTools or executing tests or doing anything, just observe.

I would then on a blank document write down everything I observed and then turn to a co-worker, and asking if it is okay for them to take a look. Then The leader of the department will also take a look, and the owner, developer team, security team will then take the lead, since they have the right tools, and the specification in that area to investigate and identify.

### **45. You don't understand something during an investigation. What do you do?**

During the investigation, if I do not understand something, I would first write down what I don't understand and then if I would be just going onto google or even from memory remembering and trying to explain to myself what it means and after work at home, I would study that thing I did not understand at home. But If I can during work, I would ask a co-worker.

### **46. You accidentally access something outside your authorized testing scope. What do you do?**

First of, I would stop immediately.

Secondly I would tell that I tested something on accident and also show logs. Because it is not something I should be hiding or trying to delete, so look into logs.

Then document what happened and tell the appropriate person, where then finally I follow their instructions on what to do next.

### **47. You find something suspicious but aren't sure whether it's actually malicious. How do you proceed?**

I could firstly document why I think it is suspicious, and then ask a coworker or an appropriate person to come check it out, because as a Junior, I cannot do tests myself, without permissions, authorization or skills I have.

### **48. A colleague asks you to test something but doesn't give you authorization. What do you do?**

Firstly, I would let them know I am not authorized for it.

Then contact the appropriate person, so that we can see if I am qualified to test something, because it all depends on the higher ups.

Then if the permissions are given and the authorization is given, then we can test safely and controlled.

For a junior I do believe someone who has more experience would be also next to me, just to make sure, we are not going over the allowed test scope and to make sure we are doing the right thing.